Vendor Due Diligence Questionnaire

Vendor Name: _____

Service Provided: _____

Assessment Date: _____

Assessed By: _____

SECTION 1: INFORMATION SECURITY

✔Does the vendor have an Information Security Policy?

✔Is the policy aligned with International Organization for Standardization ISO 27001?

✔Are security policies reviewed regularly?

✔Is there a designated security officer or team?

SECTION 2: ACCESS CONTROL

✔Are user access rights reviewed periodically?

✔Is Multi-Factor Authentication (MFA) implemented?

✔Are privileged accounts strictly controlled?

✔Is there a password policy enforced?

SECTION 3: DATA PROTECTION

✔Is sensitive data encrypted at rest and in transit?

✔Does the vendor implement data classification?

✔Are backups performed regularly?

✔Is there a secure data disposal process?

SECTION 4: INCIDENT MANAGEMENT

✔Does the vendor have an incident response plan?

✔Are incidents reported within a defined timeframe?

✔Is there a breach notification policy?

✔Are incident response tests conducted?

SECTION 5: BUSINESS CONTINUITY

✔Does the vendor have a Business Continuity Plan (BCP)?

✔Is Disaster Recovery (DR) tested regularly?

✔What is the Recovery Time Objective (RTO)?

✔What is the Recovery Point Objective (RPO)?

SECTION 6: COMPLIANCE

✔Is the vendor compliant with regulatory requirements?

✔Has the vendor undergone external audits?

✔Are certifications (ISO, SOC 2) available?

✔Are compliance reports shared with clients?

SECTION 7: RISK RATING

Criteria	Score (1–3)
Security Maturity	
Data Protection	
Compliance Level	
Operational Resilience	

Overall Risk Level: Low / Medium / High